Faculty of Science
Software Engineering Teaching Unit
University of Kelaniya, Sri Lanka

ConstructPro ERP

OWASP Top 10 Compliance Evidence

Evidence register with a re-check against develop

SENG 34213 – System Development Project

Team member	Student number
Iddamalgoda I.H.R.P.	SE/2021/038
Dhanushan K.I.	SE/2021/027
Ranasundara R.I.K.	SE/2021/001
Abeywardena M.B.	SE/2021/037

Deliverable for documents/security/owasp-checklist.pdf (guideline §10.1)

Supervisor: Dr. Nalin Warnajith
Client: Ishara Homes Pvt. Ltd.

October 2026

Chapter 1

Assessment Basis

Section 8.1 of the SENG 34213 guideline requires evidence that each OWASP Top 10 risk has been addressed. This checklist is the team's OWASP Compliance Evidence register (23 October 2026), with a re-check against the `develop` branch on the same day. The register distinguishes a control that is present in code from a passing deployment test, a clean dependency scan and an approved design review, so it records evidence rather than claiming full compliance. Where the re-check differs from the register, both statuses are shown.

The register was prepared by source inspection of the following commits, with the focused checks listed in Chapter 4.

Table 1.1: Commits inspected for the OWASP evidence register

Repository	Inspected commit	Working tree
backend	`8833e971ecc3`	Clean at inspection
frontend	`683589a7ddf5`	Clean at inspection
infra	`9048b0ff52f7`	Clean at inspection
tests	`e3bbec14c6d6`	Clean at inspection

Status definitions: **Implemented** means the source satisfies the stated mechanism. **Partial** means some implementation evidence exists but the complete requirement is not demonstrated. Because the backend and frontend moved on after the inspection, the team re-checked the register against the `develop` branch on 23 October 2026 (backend `f6bf853`, frontend `4e80694`). Where the re-check found a difference, the reconciled status is shown in the last column of Table 2.1 and explained in Chapter 5.

Chapter 2

Compliance Matrix

Table 2.1: OWASP Top 10 compliance matrix

ID	Required mitigation (guideline §8.1)	Register	Reconciled
A01	Role checks on every endpoint; unauthorised role tests return 403	Implemented	Implemented
A02	bcrypt cost ≥ 12; tokens stored as hashes; TLS enforced	Implemented	Implemented
A03	Parameterised queries / ORM throughout; validated and sanitised input	Implemented	Implemented
A04	Threat model in SDS Security section; design reviewed against it	Partial	Partial
A05	Default credentials removed; production errors hide stack traces	Implemented	Partial
A06	Dependency scan in CI; no high or critical vulnerabilities	Implemented	Partial
A07	Lockout after N failures; secure sessions; MFA optional	Partial	Partial
A08	Committed lockfiles; pipeline verifies integrity	Implemented	Implemented
A09	All auth events, errors and data access logged without PII or secrets	Implemented	Partial
A10	Validate external URL inputs; permitted-domain allow-list	Implemented	Implemented

Chapter 3

Evidence by Category

A01 – Broken Access Control.

- `JwtAuthGuard` (`backend/apps/api-gateway/src/guards/jwt-auth.guard.ts`) rejects missing or malformed bearer credentials with 401 and asks the auth service `/auth/me` to validate the identity.
- `RolesGuard` (`backend/apps/api-gateway/src/guards/roles.guard.ts`) checks normalised roles and throws `ForbiddenException` for insufficient roles. It permits execution when role metadata is absent, so attaching the guard alone does not establish a role policy; explicit `@Roles(...)` policies appear in the users, projects, quotations and client portal gateway controllers.
- Resource-level authorisation is provided by the project access policy (`backend/libs/common/src/project-access/project-access.policy.ts`), the project access service and the client portal access service. ADR-15 records service query filtering instead of PostgreSQL RLS.
- Frontend dashboard access (`frontend/src/lib/dashboardAccess.ts`) restricts navigation for usability; server authorisation remains the control.
- Authorisation tests (`tests/e2e/authorization.spec.ts`) assert 401 for anonymous callers and 403 for a restricted role, and `management-authorization.spec.ts` asserts 403. Credential-dependent cases use `test.skip`, so their existence is not proof that they executed.

A02 – Cryptographic Failures.

- `AuthService.register` hashes passwords with `bcrypt.hash(password, 12)` and `validateUser` uses `bcrypt.compare`. `UserService` defines

`BCRYPT_SALT_ROUNDS = 12` for administrator-created users, and the seed script also hashes at cost 12.

- Google Calendar tokens are encrypted with AES-256-GCM using a 32-byte configured key, random IVs and authentication tags (`backend/apps/calender-service/src/token-encryption.service.ts`).
- All Vercel and Neon connections use TLS. Refresh tokens are stateless JWTs and are not stored, so no plaintext tokens are held in the database.

A03 – Injection.

- Prisma repositories perform structured operations (for example the client and payment repositories); the payment row-lock SQL uses tagged `$queryRaw` parameters.
- The gateway installs `ValidationPipe({ whitelist: true, transform: true })`. Document DTOs validate filename, MIME type, size and category fields, and the user service adds a Zod validation pipe.
- Document DTO tests (`backend/test/document-service/document-dto.spec.ts`) passed in the focused run.

A04 – Insecure Design.

- The security model (`documents/design/security_model.md`) documents authentication, authorisation, data protection, validation and the intended OWASP controls.
- ADR-11 records service boundaries and pending review work; ADR-15 records ownership filtering and the RLS deviation. The ADRs are still marked "Proposed", and no review against a threat model is recorded, so A04 remains Partial.

A05 – Security Misconfiguration.

- The gateway exception filter returns a generic message for unexpected errors when `NODE_ENV=production`, and responses do not include a stack field.
- CI workflows consume GitHub secrets rather than embedding secret values.

A06 – Vulnerable and Outdated Components.

- The reusable workflows on the `infra` develop branch (tag `v3`) run a blocking `npm audit --audit-level=high` for backend, frontend and tests, without `continue-on-error`.
- Infra holds workflow and performance tooling without an npm manifest; its own CI validates the workflows and the performance runner. An npm scan does not cover GitHub Actions dependencies.

A07 – Identification and Authentication Failures.

- `AuthService` compares password hashes, returns a generic invalid-credentials response, and issues access and refresh JWTs with default lifetimes of 15 minutes and 7 days.
- The shared Axios client implements automatic refresh. Google session tests (`backend/test/auth-service/google-session.spec.ts`) and frontend Google auth tests (`frontend/test/google-auth.test.mjs`) passed in the focused run.

A08 – Software and Data Integrity Failures.

- `package-lock.json` is tracked in the backend, frontend and tests repositories.
- All reusable CI workflows install with `npm ci`, which checks package and lockfile consistency and verifies package integrity metadata.

A09 – Security Logging and Monitoring Failures.

- The gateway exception filter logs status, code, trace ID, message and URL; the JWT guard logs token-validation failure codes.
- The auth gateway `forwardOAuth` logs bounded failure metadata and explicitly avoids logging authorisation codes, locations, tokens and bodies.
- `LoggingInterceptor` (`backend/libs/common/src/interceptors/logging.interceptor.ts`) records method, URL and duration, but it is not registered in any application, so its definition alone is not evidence of active audit coverage.

A10 – Server-Side Request Forgery.

- The AI provider calls a fixed HTTPS OpenRouter endpoint rather than a request-supplied URL.
- The document upload DTO accepts file metadata, not a download URL, and storage identifiers are created server-side.
- `CloudinaryService.downloadAuthenticatedAssetBytes` derives URLs through the provider SDK, rejects redirects (`redirect: 'error'`), uses a timeout and bounds the downloaded bytes.
- OAuth forwarding disables automatic redirects and validates the Google authorisation origin; this is a redirect control rather than a universal allow-list.

Chapter 4

Checks Executed

All commands were run on 23 October 2026. The passing checks are narrowly scoped and do not replace penetration testing or release CI.

Table 4.1: Security checks executed

Repository	Command (from repository root)	Observed result
backend	`jest --config jest.unit.config.js --runInBand --runTestsByPath` with the project-access policy, Google session, Cloudinary service and document DTO specs	4 suites, 65 tests passed
frontend	`node --test test/roles.test.mjs test/dashboard-access.test.mjs test/google-auth.test.mjs`	15 tests passed, no skips
infra	`node --test tests/performance/runner.test.mjs`	5 tests passed; validates the performance tooling, not deployed compliance
tests	`playwright test --list`	44 tests discovered in 9 files; discovery only
backend	`npm audit --audit-level=high` on `develop` (`f6bf853`), re-check	5 high-severity advisories (follow-redirects; mysql2 through the Prisma CLI)
frontend, tests	`npm audit --audit-level=high`, re-check	0 vulnerabilities

The tests repository enables deployed end-to-end runs only on manual dispatch, and its caller workflow does not yet forward the accountant credentials used by `management-authorization.spec.ts` or several optional client-portal inputs. These must be

configured, and the skip counts kept, before a green discovery job can be presented as a completed authorisation test run.

Chapter 5

Re-check Findings and Actions

Table 5.1: Re-check findings and actions

ID	Finding on develop (23 October 2026)	Action
A05	The gateway enables CORS with `origin: true` and credentials, which reflects any origin; no security headers (helmet) are set.	Restrict CORS to the frontend origin(s) and add helmet
A06	The backend caller pins `infra/.github/workflows/backend-ci.yml@v2.0.0`, where the audit step is `npm audit --omit=dev --audit-level=high` with `continue-on-error: true`. The blocking audit exists only in `v3`. `npm audit` currently reports 5 high-severity advisories in the backend. The tests caller pins `@v1`, which has no audit step, and the frontend caller's `@v1` audit covers production dependencies only.	Merge `fix/resolve-vulnerable-dependencies` after review, then move the backend, frontend and tests callers to `@v3`
A07	No rate limiting or account lockout on login; refresh tokens cannot be revoked or rotated server-side.	Add throttling and lockout; persist and rotate refresh tokens
A09	Data access is not logged: `LoggingInterceptor` is unregistered and the `AuditLog` table is never written.	Register the interceptor and write audit log entries for approvals, payments, deletions and role changes

Before submission
When the actions in Table 5.1 are completed, re-inspect at the final commits and update the Reconciled column of Table 2.1. Until then, the Reconciled column is the status to present.